

韩天硕

(+86) 173-3953-9195 | hantianshuo@jie.ac.cn | github.com/keymaker-arch

安全研究员 / 漏洞挖掘与利用 / Linux 内核安全

教育经历

中国科学院大学，信息工程研究所 | 网络空间安全，直博在读 2021.09 – 2027.01 (预计)

- 研究方向：Linux 内核安全、漏洞挖掘与利用、模糊测试、AI for Security。
- 代表成果发表于 IEEE S&P、USENIX Security、ACM CCS 等世界顶级安全会议。

中国农业大学，生命科学学院 | 生物科学，理学学士 2017.09 – 2021.06

- 跨专业保送至中国科学院大学网络空间安全专业直博；曾获全国大学生数学建模竞赛国家级一等奖、CUPT 青年物理学家竞赛华北赛区一等奖、iGEM 国际基因工程机器大赛金奖。

学术成果

NetPanic: The Attack Surface You Can't Syscall

Tianshuo Han, Zong Cao, Zhen Dong, Xiapu Luo, Zhenyu Song, and Jian Liu

47th IEEE S&P, 2026, CCF-A 类顶级安全会议

- 提出 Fuzzer-in-the-Middle 网络协议模糊测试架构，首次系统地测试 Linux 内核网络栈远程攻击面，发现 15+ 个远程可触发内核漏洞。
- 负责核心架构设计与实现、LibAFL 定制、漏洞复现、实验评估及论文主要撰写。

CARDSHARK: Understanding and Stabilizing Linux Kernel Concurrency Bugs Against the Odds

Tianshuo Han, Xiaorui Gong, and Jian Liu

33rd USENIX Security, 2024, CCF-A 类顶级安全会议

- 分析 Linux 内核竞争漏洞触发不稳定的根因，提出了一种通用的竞争漏洞利用技术，显著提升漏洞利用成功率和可复现性。
- 负责竞争漏洞机理分析、利用技术研发、性能评估与论文主要撰写。

Venom: Kernel Fuzzing of Distributed File Systems via Intra-Cluster Protocol Poisoning

Zong Cao, Tianshuo Han (共同一作), 等

ACM CCS, 2026, CCF-A 类顶级安全会议 (在投)

- 提出 Mutation-in-the-Middle 及静态分析引导变异算法，在内核分布式文件系统发现 30+ 个内核漏洞。
- 负责变异算法设计与实现、实验设计、漏洞复现及结果分析。

Wire to Ring Zero: The Remote Kernel Attack Surface That Years of Fuzzing Never Reached

Tianshuo Han, Zong Cao

Black Hat USA, 2026, 顶级安全工业会议 (在投)

- 从工业攻防视角梳理远程内核攻击面，提出面向 Linux/Windows 内核网络栈实现的中间人模糊测试方法。

Reviving Discarded Vulnerabilities: Exploiting Previously Unexploitable Linux Kernel Bugs Through Control Metadata Fields

Hao Zhang, Jie Lu, Shaomin Chen, Tianshuo Han, Bolun Zhang, Jian Liu, Xiaorui Gong

32nd CCS, 2025, CCF-A 类顶级安全会议

- 提出基于内核结构体关键元数据字段操控的利用技术，增强弱漏洞原语场景下的利用能力，扩展可利用漏洞范围。
- 参与核心思路制定、评估实验设计及审稿意见回复。

Whole-genome sequence and comparative analysis of *Trichoderma asperellum* ND-1

Fengzhen Zheng, Tianshuo Han, et al. | Catalysts 12(4), 2022, IF=4.16

- 负责基因组数据分析与科学数据可视化，辅助揭示该菌株木质纤维素降解酶系统。

项目实践

NetPanic：面向 Linux 内核网络栈的 FitM 模糊测试框架2023.11 – 至今

- 设计区别于 Syzkaller 的在途中间人模糊测试架构，面向 NFS/CIFS/NFSD/ksmbd 等网络路径提升远程攻击面覆盖。
- 基于 LibAFL 深度定制变异、执行、反馈、调度等核心组件，独立完成 40K+ 行 Rust/C 实现。
- 支撑 IEEE S&P 2026 论文与多项远程可触发 Linux 内核 CVE 发现。

Venom：Mutation-in-the-Middle 变异算法2026.03 – 至今

- 设计静态分析引导的高效变异算法，针对 Fuzzer-in-the-Middle 架构中的网络协议状态、消息依赖和污染传播进行优化。
- 基于 LibAFL 与 LLVM IR 实现，代码规模 50K+ 行 (Rust/C/Python)，支撑分布式文件系统漏洞发现。

自动化漏洞审计与复现 Agent2026.03 – 2026.04

- 基于 ClaudeCode/Codex SDK 构建端到端全自动安全审计 Agent，覆盖漏洞发现、环境搭建、复现、PoC 生成和报告撰写。
- 在 HTTPD、QEMU、libexif 等开源项目中发现 10+ 个漏洞并获得 CVE。

Linux 内核 Rootkit 与隐蔽机制研究2023.12 – 2024.05

- 独立实现自身隐藏、端口隐藏、权限提升、文件/进程隐藏、开机自启等核心机制，用于内核攻防技术验证。
- 强调轻量化、高隐蔽性与跨版本兼容，支持 Linux 2.6 至 6.3 系列内核并规避常见 Rootkit 检测策略。

类 Linux 内核开发2020.12 – 2021.05

- 从零实现可运行的类 Linux 内核，覆盖引导、内存管理、进程调度、系统调用和文件系统等核心子系统；代码规模约 20K 行 (C/x86 汇编)。

安全贡献

Linux 内核远程可触发漏洞5 项

- CVE-2025-38089: sunrpc 空指针解引用，可远程触发内核崩溃
- CVE-2025-38051: CIFS 客户端 cifs_fill_dirent 释放后重用
- CVE-2025-40210: NFSD 远程 COMPOUND 请求内存分配失败拒绝服务
- CVE-2025-40212: NFSD 伪根文件句柄引用计数泄漏，导致 UAF 与拒绝服务
- CVE-2026-23220: ksmbd SMB2 请求处理无限循环远程拒绝服务

开源项目漏洞5 项

- CVE-2026-28780、CVE-2026-34032: 暂未公开披露
- CVE-2026-40312: ImageMagick MSL 解码器 XML 分组解析堆越界写入 (off-by-one)
- CVE-2026-40385: libexif Nikon MakerNote 32 位无符号整数溢出，导致崩溃或信息泄露
- CVE-2026-40386: libexif Fuji/Olympus MakerNote 尺寸校验整数下溢，导致崩溃或信息泄露

技术能力与其他

- 内核安全：Linux 内核漏洞挖掘与利用、远程攻击面分析、Rootkit 机制、二进制逆向与利用。
- 安全能力：熟练掌握网络、系统和密码等网络安全基础；熟悉 LibAFL、AFL++、Syzkaller、LLVM、CodeQL 等模糊测试和静态分析框架；熟练使用 GDB、IDA 等程序调试和逆向工具；熟练使用各种渗透测试工具。
- 编程语言：精通 C 和 Rust；熟练掌握 Python、Shell、x86 汇编、LaTeX，可以使用各种主流编程语言。
- AI 与 Harness：熟练掌握 Agentic 编程工作流，可以快速完成开发任务和安全测试任务。
- 教学经历：曾任中国科学院大学《恶意软件发现与分析》课程助教；
- 外语能力：英语读写能力与母语者接近，可熟练阅读、撰写英文论文和技术文档。